SafeOps — Product Requirements Document

Company: MedChain Enterprise · **Product:** SafeOps · **Tagline:** Safety Intelligence Platform **Version:** 1.0 (for founder approval) · **Date:** 15 July 2026 · **Author:** Co-Founder / CPO **Status:** ⏳ AWAITING APPROVAL — no code until sign-off

---

0. Executive Summary

SafeOps turns safety data into decisions. Not a form-filling system, not a document store — a decision engine that tells an HSE Manager *what to do next* and gives a CEO a defensible answer to "are we safe?"

The strategic wedge: mid-size and large enterprises in Southeast Asia run safety on spreadsheets, WhatsApp groups, and paper. Global tools (Intelex, Enablon) are too heavy and too expensive; SafetyCulture owns checklists but is weak on investigation workflow and executive intelligence. **Nobody owns "safety intelligence for the SEA enterprise."** That is our category.

This PRD does three things:

1. **Critiques the current prototype honestly** and cuts what doesn't survive first-principles scrutiny.
2. **Specifies the real product** — tenancy, roles, workflows, data model, scoring math — precisely enough that senior engineers can build without follow-up questions.
3. **Sequences the roadmap** so we ship a sellable MVP in ~12 weeks, not a 12-month platform.

0.1 Critique of the Current Prototype (v0)

The v0 frontend (live at safeops-5wr.pages.dev) is a good *sales demo* and a wrong *product*. Specific failures, called out so we never rationalize them:

#	Weakness	Consequence	Verdict
1	**All data is hardcoded.** No backend, no persistence, no auth.	It's a movie, not software.	Rebuild on a real stack (this PRD).
2	**Read-only theater.** "Report Incident," "Verify now," "Advance stage" buttons do nothing. The product claims decision-support but can't record a decision.	Fails our own philosophy test on every screen.	Every CTA must mutate state or not exist.
3	**No capture funnel.** Analytics presume incident data exists, but there is no path for a worker to create it. Safety data is born in the field — often offline, often not in English.	The platform starves. Garbage-in doesn't even apply; it's *nothing-in*.	Mobile-first capture becomes a P0 module.
4	**Three modules answer one question.** Executive Dashboard, Executive Analytics, and Root Cause Analytics all show trends; Site Intelligence duplicates the dashboard's site ranking.	Nav sprawl; users won't know where to look; demos ramble.	Consolidate: **one place per question** (see IA, §6).
5	**The Safety Score is a black box.** A number (84) with no formula, no drill-down, no defensibility.	The first serious HSE Manager will ask "how is this computed?" and we die in the meeting.	Published formula + explainability drawer (§21.3). Every number clickable to its inputs.
6	**No notification/escalation engine** — the UI *claims* "owners are nudged 7 days before due" but nothing sends anything.	Corrective actions are only valuable if the system chases people. The chasing IS the product.	Notification Center is MVP, not v2 (§18).
7	**Single hardcoded persona.** "Good morning, Randy," no roles, no permissions.	Enterprise = many roles with conflicting needs. A CEO and a Safety Officer must not see the same home screen.	RBAC + role-adaptive home (§14).
8	**No audit trail.** Records can be silently changed.	Compliance-grade products require evidence-grade history. Regulators and lawyers will subpoena this data.	Append-only audit log on every mutation (§13).

#	Weakness	Consequence	Verdict
9	**KPI math has no denominators.** TRIFR needs hours worked; nothing collects hours worked.	Every rate metric is fiction.	`work_hours` entry is a first-class (boring, essential) feature.
10	**Unverifiable claims baked into UI** ("RM 2.4M cost avoided").	Destroys trust with a sophisticated buyer the moment they probe it.	Cut until we have a real, disclosed model.

What we keep from v0: the visual system (validated palette, dark/light tokens, density), the "Needs your attention" feed concept (it becomes the product's spine), the demo narrative discipline (data that tells one coherent story), and the league-table + heatmap presentation patterns. v0 is retained as the **marketing/sales demo** while the real product is built.

---

1. Product Vision

By 2030, SafeOps is the safety intelligence layer for industrial Southeast Asia — the system a CEO opens before a board meeting, an HSE manager opens every morning, and a regulator accepts as the record of truth. When an executive anywhere in MY/ID/VN/TH asks "are we safe?", the answer comes from SafeOps, with the receipts to prove it.

2. Product Mission

Help HSE Managers, Safety Officers, Operations Managers, and CEOs make faster, smarter safety decisions by converting field data into ranked, explainable, actionable intelligence — replacing spreadsheets, paperwork, and gut feel.

3. Product Strategy

Positioning: "Decision intelligence," not "safety management." We do not compete on the number of forms. Every competitor stores information; we rank what matters and prescribe what to do next.

Wedge → Land → Expand:

1. **Wedge (MVP):** The incident-to-closure loop plus the executive dashboard. This is where spreadsheets hurt most: a group HSE manager at a 6-site company loses ~3 days per month consolidating site reports. We collapse that to zero and give the CEO a live answer.
2. **Land:** 3–5 design-partner companies in Sarawak/Malaysia (manufacturing, plantation, O&G services) at founder-led pricing. Success = they run their monthly safety review meeting *inside* SafeOps.
3. **Expand:** Inspections/checklists (v2), regulatory e-reporting (JKKP/DOSH forms — a real SEA moat, §11), contractor management, then AI-native intelligence (v3). Seat expansion is organic: every corrective action assigned to a new owner is a new user.

Moats (in order of durability):

1. **SEA regulatory depth** — pre-built OSHA 1994/Act 514 (with 2022 amendments), CIMAH, NADOPOD/JKKP reporting, BM-first field UX. Global vendors won't localize this deeply; local vendors won't match the product quality.
2. **The scoring system** — an explainable, benchmarkable Safety Score that becomes the number boards ask for.
3. **Cross-tenant benchmarks** (v3, anonymized, opt-in) — "your TRIFR vs. industry P50" is data nobody else in the region has.

Pricing hypothesis (validate with design partners): per-site platform fee (RM 800–2,500/site/month by tier) + included seats, with **free unlimited reporter-level users** — capture must never be metered, because capture feeds the intelligence. Action owners are free. Paid seats = Safety Officer and above.

What we deliberately do NOT build (now): permit-to-work, LMS/training delivery, document management systems, IoT/sensor ingestion, behavior-based safety programs. Each is a company on its own; each dilutes the wedge.

4. User Personas

Persona	Role	Frequency	Device	Core question	Pain today	Success metric
Datuk Faridah	CEO / Group MD	Monthly, 5 min	Phone, board pack	"Are we safe, improving, audit-proof? What needs my weight?"	Gets a 40-slide deck 3 weeks late; surprises at board level	Zero surprises; one screen before every board meeting
Marcus Tan	Group HSE Manager *(economic buyer + power user)*	Daily, 30–60 min	Desktop	"Where is risk concentrating and who is not closing actions?"	Consolidates 6 sites' spreadsheets monthly (~3 days); chases owners by phone	Monthly review runs live from SafeOps; consolidation time → 0
Priya	Plant / Site Manager	Weekly	Desktop + phone	"Is my site's score defensible? What do I approve or push?"	Learns about incidents late; no view of her own trend	Sees her score's drivers; approves closures in-app
Hafiz	Site Safety Officer	All day	Phone in the field	"What's in my queue? What evidence is missing?"	Paper forms, photos in WhatsApp, retyping into Excel	Investigation started on-scene from his phone
Ganesh	Maintenance Supervisor *(action owner)*	Only when assigned	Phone, via link	"What exactly must I do, by when, and how do I prove it done?"	Verbal assignments, no reminders, blamed later	Completes + attaches evidence from a link, no training needed
Aina	Frontline worker *(reporter)*	Rarely; must be instant	Phone, BM language	"How do I report this hazard in under a minute?"	No channel; reports die in supervisors' notebooks	QR-scan → 45-second report, in Bahasa Malaysia, offline-capable

Design law derived from personas: **the product must be excellent at 3 altitudes** — glance (Faridah), manage (Marcus/Priya), and do (Hafiz/Ganesh/Aina) — and must never show one altitude's UI to another altitude's user by default.

5. User Journeys

J1 — Near-miss capture (Aina, 45 seconds): Scans QR poster at her station → capture form opens with site/location prefilled from the QR → picks category chips (BM labels + icons) → snaps photo → taps submit. Offline? Report queues in the device outbox and syncs later, with visible "will send when online" state. She optionally leaves a phone number for follow-up; anonymous is allowed (configurable per tenant). *Value delivered to her:* a "your report led to a fix" notification when the linked action closes — this closes the reporting-culture loop.

J2 — Triage & investigation (Hafiz): Morning queue shows new reports ranked by severity-proxy heuristics → he triages: dismiss-duplicate (with reason), log-as-hazard, or **promote to incident** → promoting starts the state machine (§21.1): he's investigation lead by default, evidence checklist generated by incident type, witness statements captured as voice-note + transcription (v2) or text → completes 5-Why RCA → RCA requires Site Manager approval for Serious+ → raises corrective actions with owners and due dates.

J3 — Monthly review (Marcus): Opens Analytics → period auto-set to last month → reviews score movements with explainability drawers → exports the board pack (PDF, one click, pre-formatted) → in the meeting, drills live into any number when challenged → assigns follow-ups as corrective actions *in the meeting*. No PowerPoint is produced by a human.

J4 — Executive glance (Faridah): Opens phone → role-adaptive home: two scores, the Decision Feed (≤5 items, each with a recommended action), days-since-LTI → taps one feed item → reads the 3-sentence brief → forwards it to Marcus with one tap ("act on this"). Total: 4 minutes.

J5 — Audit prep (Marcus + Priya, 6 weeks out): Compliance module shows readiness per standard, majors-first queue with owners and dates → each closed item requires attached evidence → the auditor-facing export bundles clause status + evidence index. The audit stops being a fire drill.

6. Information Architecture

First-principles rule: **one place per question.** v0's seven modules collapse to six surfaces plus admin.

```
SafeOps
├── Home                    "What needs attention right now?"      (role-adaptive)
│   ├── Decision Feed       ranked, explainable, actionable
│   ├── Scores              Safety Score + Compliance Score (drill-down)
│   └── KPI strip           TRIFR · LTI-free days · open incidents · overdue actions
├── Incidents               "What happened and where does each case stand?"
│   ├── Queue               triage inbox (reports → hazards/incidents)
│   ├── Pipeline            board by workflow state
│   └── Case view           investigation · RCA · evidence · linked actions
├── Actions                 "Who owes what, and what's slipping?"
│   ├── Tracker             all corrective actions, aging, escalation state
│   └── Verification queue  evidence review before closure
├── Analytics               "How is performance changing, and why?"
│   ├── Trends              incidents, near-misses, TRIFR vs target
│   ├── Root causes         category trends · cause × site heatmap
│   ├── Comparisons         site league table · department comparison
│   └── Board pack export
├── Compliance              "Will we pass the audit?"
│   ├── Standards           readiness % per framework, clause status
│   └── Findings queue      majors-first work list with evidence
├── Notifications           "What is the system telling me?"
│   └── Center + preferences (digest, channels, quiet hours)
└── Admin                   org · sites · departments · users · roles · work hours · imports
```

Explicit consolidations from v0: Executive Analytics + Safety KPI Dashboard + Trend Analysis → **Analytics**. Site Comparison + Department Comparison → **Analytics ▸ Comparisons**. Root Cause Analysis (the analytics half) → **Analytics ▸ Root causes**; the workflow half lives inside the incident case view. Incident Management + Incident Investigation → **Incidents** (one module, one state machine). Audit Readiness + Compliance Score → **Compliance**. All 13 requested MVP modules exist — as views, not as nav items.

7. Navigation Structure

- **Sidebar (desktop):** the 6 surfaces + Admin. Hard cap: 7 items forever. New capabilities become tabs inside surfaces, never new nav items.
- **Global context bar:** org/site scope selector (respects permissions), time-period selector, data-freshness stamp. Scope + period persist across surfaces — changing site in Analytics carries to Incidents.
- **Command palette (⌘K):** entities (INC-2607, CA-440), people, and actions ("report incident," "export board pack"). Power users live here.
- **Mobile (PWA):** bottom tabs — Home · Report (center, prominent) · My Queue · Notifications. Capture is one tap from anywhere.
- **Deep links everywhere:** every entity, filter state, and drill-down is a URL (path routing, not hash). Links pasted into WhatsApp must open the exact view — in SEA, WhatsApp *is* the intranet.
- **Role-adaptive Home:** Executive → scores + feed. HSE Manager → feed + org KPIs. Safety Officer → My Queue. Action owner → My Actions. Same URL, different default composition; user can pin preferences.

8. Dashboard Layout (Home, desktop)

```
┌────────────────────────────────────────────────────────────────┐
│ Context bar: [All sites ▾] [Last 12 months ▾]   fresh 8 min ago│
├──────────────────────────────────────┬─────────────────────────┤
│ A · DECISION FEED (⅔ width)          │ B · SCORES (⅓)          │
│  ≤5 ranked items. Each item:         │  Safety Score ring      │
│  severity chip · one-line insight ·  │  Compliance ring        │
│  evidence link · recommended action  │  → click = explain      │
│  · assign/snooze/dismiss (audited)   │    drawer: component    │
│                                      │    weights & inputs     │
├──────────┬───────────┬───────────┬───┴───────┬─────────────────┤
│ C · KPI strip: TRIFR │ LTI-free │ Open inc. │ Overdue actions  │
│  (each tile deep-links to its source view)                     │
├──────────────────────────────────────┬─────────────────────────┤
│ D · Incident vs near-miss trend      │ E · Site league table   │
│     (12-mo, one axis)                │    score·Δ·status band  │
└──────────────────────────────────────┴─────────────────────────┘
```

Decision Feed contract (the product's spine): every feed item is generated by a named rule (§21.4), carries its evidence (deep link to the chart/list that justifies it), a recommended action, and lifecycle (assign → track / snooze with reason / dismiss with reason — all audited). Feed items are how "intelligence" ships incrementally: MVP items are rule-based; v3 items are model-based. The UI contract never changes.

Layout laws: answer "what should I do next?" above the fold; nothing purely decorative; every number clickable to its inputs; empty states teach (a new tenant's home explains how to get data in, with import + QR-poster CTAs).

9. Feature Prioritization

Method: MoSCoW against the wedge, tie-broken by RICE. "Does this help close the loop from *field event → decision → verified fix*?" If no, it waits.

Feature	MoSCoW	Rationale
Multi-tenant auth, RBAC, audit log	Must	Nothing is enterprise-sellable without it
Incident lifecycle (capture→triage→investigate→RCA→close)	Must	The wedge
Corrective actions + escalation + verification	Must	The chasing is the product
Mobile PWA capture (offline, QR, BM/EN)	Must	Feeds everything; free-reporter model depends on it
Home + Decision Feed (rule-based)	Must	The differentiator; the demo; the daily habit
Analytics (trends, comparisons, root causes)	Must	The buyer's monthly job
Safety/Compliance scores w/ explainability	Must	The number the board asks for
Notification center + email + digests	Must	Escalation ladder can't exist without it
Work-hours entry + CSV import	Must	Denominators; migration path from spreadsheets
Board-pack PDF export	Should	High buyer value, low complexity — MVP if schedule holds
WhatsApp notifications	Should→v2	High SEA value; needs Business API approval + cost
Inspections / checklists	Won't (v2)	SafetyCulture's turf; enters as feed-input later
JKKP/DOSH regulatory e-reporting	Won't (v2)	Real moat, but needs legal verification of formats
SSO (SAML/OIDC), SCIM	Won't (v2)	Design partners don't need it; enterprise deals do
AI classification / prediction	Won't (v3)	Needs data volume first; rules deliver 80% of feed value now
Permit-to-work, LMS, IoT	Won't	Different products

10. MVP Scope

Definition of done for MVP: a design-partner company runs its real safety program on SafeOps for 60 days without spreadsheets. Target: ~12 weeks to pilot-ready.

Included modules & acceptance criteria

M1 — Foundation (weeks 1–3): Tenancy, auth (email+password, strong policy, TOTP 2FA optional), RBAC per §14, org/site/department admin, user invites, append-only audit log, CSV import (incidents, actions, hours), work-hours entry. *Accept:* two tenants cannot see each other's data even via direct API calls (RLS test suite proves it); every mutation writes an audit event; a new tenant reaches "first incident recorded" in <15 minutes from invite.

M2 — Incident pipeline (weeks 3–6): Report capture (web + PWA offline), triage queue (promote/hazard/dismiss-with-reason), state machine per §21.1 enforced server-side, investigation workspace (findings, timeline, witness statements), 5-Why RCA with category taxonomy per §21.2, evidence upload (photos/docs, checksummed), approval gates (Serious+ requires Site Manager RCA approval; closure blocked while linked actions open). *Accept:* a worker with no account reports via QR in <60s on a 3G connection; offline report syncs; an invalid state transition returns 422 from the API regardless of UI; closing an incident with open actions is impossible.

M3 — Actions + notifications (weeks 5–8): Action CRUD with owner/due/priority/progress, evidence-required completion, verification queue, escalation ladder per §18, notification center, email delivery, weekly digest, magic-link access for action owners (no password onboarding for Ganesh). *Accept:* an overdue action escalates on schedule with zero human involvement; an action owner can complete + attach evidence from an email link on a phone in <2 minutes; verification rejection reopens with a reason.

M4 — Intelligence & compliance (weeks 8–12): Home with Decision Feed (initial rule set §21.4), Safety/Compliance score engine + monthly snapshots + explainability drawers, Analytics (trends, site/department comparisons, root-cause views), Compliance module (standards, clause assessments, findings queue, evidence), board-pack PDF export, notification preferences. *Accept:* score reproduces from stored snapshot inputs (property-tested); every feed item's evidence link lands on a view proving it; the pilot's monthly safety meeting runs from Analytics with no exported spreadsheet.

Explicitly OUT of MVP

Inspections, JKKP e-filing, WhatsApp channel, SSO/SCIM, native apps, benchmarking, AI features, contractor portal, custom dashboards, API keys/webhooks, billing self-serve (contracts are founder-signed at this stage).

Pilot success metrics

3 design partners live · activation = 25 field reports in first 30 days per tenant · ≥60% actions closed on time by day 60 · exec views ≥1×/week · HSE-manager NPS ≥ 40 · zero cross-tenant data incidents.

11. V2 Roadmap (months 4–9) — "Own the compliance workflow"

1. **JKKP/DOSH regulatory reporting** — generate JKKP 6/7/8 + NADOPOD-compliant notifications from incident data; track statutory deadlines in the Decision Feed. *The moat feature.*
2. **Inspections & checklists** — scheduled site inspections feeding the score's leading indicators and the feed (overdue inspection = feed item). Entering SafetyCulture's turf from the intelligence side.
3. **WhatsApp notifications** (Business API) — escalations and action links where SEA users actually live.
4. **SSO (SAML/OIDC) + SCIM** — unlocks large-enterprise procurement.
5. **Witness voice-notes with transcription + BM↔EN translation** of narratives.
6. **Contractor management lite** — contractor companies as first-class entities with their own scorecards (contractors were the worst performer in every dataset we've seen).
7. **Custom report builder + scheduled email reports.**
8. **Read-only board/investor share links** (expiring, watermarked).

12. V3 Roadmap (months 9–18) — "Intelligence nobody else has"

1. **AI-assisted intake:** narrative → suggested type/severity/root-cause classification (human confirms — §20 guardrails).
2. **Similar-incident retrieval:** "3 prior cases match this pattern; 2 shared the same failed control."
3. **Predictive risk index:** leading-indicator model flagging site/department risk *before* the incident; feed items with confidence bands. Requires ≥12 months tenant data.
4. **Ask-your-data:** natural-language analytics ("show forklift incidents at night shift this year, by site").
5. **Anonymized industry benchmarking** (opt-in): TRIFR/score percentiles by industry and size — the data network effect.
6. **Regulation watch:** DOSH/legal updates mapped to affected clauses, gap suggestions.
7. **Native mobile apps** — only if PWA friction is proven by data.
8. **Single-tenant deployment tier** for O&G majors and government-linked companies.

13. Database Concept

Stack decision: PostgreSQL (single cluster, region ap-southeast-1/Singapore) + Prisma. Multi-tenancy via `tenant_id` on every tenant-owned row, enforced by **Postgres Row-Level Security** with a session-scoped GUC set per request — plus an application-layer guard (belt and suspenders). Object storage (R2/S3, SG region) for evidence with SHA-256 checksums and signed URLs.

Core entities (~20 tables):

Entity	Key fields / notes
`tenants`	name, plan, region, settings jsonb, locale defaults
`users`	email (citext unique), name, locale, totp_secret?; global identity
`memberships`	user↔tenant, `role` enum (§14), `site_scope` uuid[] (empty = org-wide)
`sites`	tenant_id, name, industry enum, timezone, address, qr_code_key
`departments`	site_id, name
`locations`	site_id, label, qr_key — QR posters map to these
`reports`	raw field submissions: reporter (user_id nullable — anonymous allowed), site/location, category, narrative, photos, `status` (new/promoted/hazard/dismissed), dismissed_reason
`incidents`	tenant/site/dept, `class` (incident | near_miss — **one pipeline, one table**; near-miss is an incident row, which makes ratio analytics trivial), type enum, severity enum, `status` enum (§21.1), occurred_at, reported_at, title, narrative, reporter_ref, lead_id, is_lti bool, days_lost int
`investigations`	incident_id 1:1, findings text, timeline jsonb, witness_statements jsonb[]
`rca`	incident_id 1:1, method enum (five_why | fishbone), category enum (§21.2), sub_category, five_why jsonb, contributing_factors jsonb, approved_by, approved_at
`actions`	tenant/site, incident_id nullable (standalone allowed), owner_id, title, description, priority, due_date, progress, `status` enum (open | in_progress | completed | verified | rejected), verified_by/at, escalation_level int
`action_updates`	action_id, author, note, progress_delta, created_at
`attachments`	polymorphic (parent_type, parent_id), kind, storage_key, sha256, size, uploaded_by
`work_hours`	site_id, month (date), hours int, headcount int, source (manual | import) — unique(site, month)
`standards`	tenant_id, framework (iso45001 | osha514 | cimah | fire | custom), name, next_audit_date
`clauses`	standard_id, code, text, weight smallint
`assessments`	clause_id × site_id, status (compliant | minor | major | na), evidence_attachment?, assessed_by/at, due_date
`score_snapshots`	site_id, month, safety_score, compliance_score, `components` jsonb (every input frozen — scores must be reproducible forever)
`feed_items`	tenant, rule_key, severity, title, detail, evidence_url, recommended_action, state (active | assigned | snoozed | dismissed), state_reason, acted_by

Entity	Key fields / notes
`notifications`	user_id, type, payload jsonb, channels_sent jsonb, read_at
`notification_prefs`	user_id: channel toggles, digest day, quiet hours
`audit_log`	tenant, actor, action, entity_type/id, before/after jsonb, ip, at — **append-only** (no UPDATE/DELETE grants; enforced at the DB role level)

Derived data: `site_month_stats` materialized rollups (incident counts by class/severity/cause, action aging, TRIFR inputs) refreshed on write (async) + nightly reconciliation. Dashboards read rollups and snapshots, never aggregate raw tables at request time — this is how p95 stays low at 10,000 incidents.

Conventions: UUIDv7 PKs; all timestamps UTC (`timestamptz`), displayed in site timezone; soft-delete only where legally safe (incidents are never hard-deleted); enums in Postgres for state fields so invalid states are unrepresentable.

14. Roles & Permissions

Seven roles. Permissions are **role × scope** (org-wide or site-scoped via `memberships.site_scope`).

Capability	Reporter	Action Owner	Safety Officer	Site Manager	HSE Manager	Executive	Org Admin
Submit field report	✅	✅	✅	✅	✅	✅	✅
Triage reports / manage incidents	—	—	✅ site	✅ site	✅ org	—	—
Approve RCA (Serious+)	—	—	—	✅ site	✅ org	—	—
Complete assigned actions	—	✅ own	✅	✅	✅	—	—
Verify action completion	—	—	✅ site*	✅ site	✅ org	—	—
Close incidents	—	—	—	✅ site	✅ org	—	—
View analytics	—	—	✅ site	✅ site	✅ org	✅ org	✅ org
Manage compliance assessments	—	—	✅ site	✅ site	✅ org	—	—
Act on Decision Feed	—	—	✅ site	✅ site	✅ org	assign only	—
Manage users/sites/settings	—	—	—	—	invite only	—	✅
Export data / board pack	—	—	✅ site	✅ site	✅ org	✅ org	✅ org
View audit log	—	—	—	—	✅ org	—	✅

* Safety Officers cannot verify actions they own (separation of duties, enforced server-side).

Principles: Reporters are free and near-anonymous (no dashboard access — they get status updates on their own reports only). Action Owners authenticate via magic link; they see only their actions. Deny-by-default; every API route declares its required capability; capability checks are middleware, not per-handler ad-hoc logic.

15. Multi-Company (Tenant) Architecture

- **Isolation:** single Postgres cluster, RLS on `tenant_id` (session GUC set from the authenticated JWT per request), verified by an automated cross-tenant test suite that runs in CI against every endpoint. Object storage keys are tenant-prefixed; signed URLs are tenant-checked at issue time.
- **Identity:** users are global (one email, one account) with per-tenant memberships — consultants and group-of-companies structures need this. Tenant switcher in the account menu.
- **URLs:** path-scoped at MVP (`app.safeops.app` , tenant from session); per-tenant subdomains (`acme.safeops.app`) in v2 when SSO lands (SAML wants stable entity URLs).
- **Tiers:** shared cluster (standard) → dedicated schema/DB (enterprise, v3) → single-tenant deployment (v3, O&G/GLC). Same codebase, config-driven.
- **Tenant lifecycle:** self-serve trial creates a sandboxed tenant seeded with the demo dataset (clearly watermarked "sample data — clears on first real import"); offboarding = full export (JSONL + attachments) then scheduled hard-delete with

certificate.

16. Multi-Site Architecture

- **Hierarchy:** tenant → site → department (three levels, fixed, at MVP). A `region` grouping layer between tenant and site is v2 — conglomerates will ask; do not build speculatively.
- **Scoping:** every operational record carries `site_id`. Site-scoped staff see only their sites (RLS + membership scope). Org roles see all with site filters.
- **Rollups:** org-level metrics are weighted aggregations of site snapshots (hours-weighted for rates, headcount-weighted for scores) — computed in the snapshot job, never ad hoc, so the org number always reconciles with the site numbers beneath it.
- **Site comparability:** league tables display industry + headcount context and use *rates*, not raw counts (a 1,240-worker plant vs a 310-worker warehouse must be fairly comparable). Score bands (healthy ≥85 / watch 70–84 / intervene <70) are tenant-configurable with our defaults.
- **Timezones:** each site has a tz; "days since LTI" and monthly bucketing compute in site-local time; org rollups use tenant HQ tz.

17. Mobile Experience

Decision: installable PWA, not native, until data proves otherwise. Rationale: capture is the mobile job; PWA does offline capture well; two native codebases would consume half the team for zero wedge value.

- **Capture in <60 seconds:** QR poster → location-prefilled form → category chips (icons + BM/EN labels, tenant-customizable) → photo (client-side compressed to ≤300KB) → submit. Maximum 6 required fields. Anything optional is behind "add more details."
- **Offline-first:** service worker + IndexedDB outbox; queued reports show sync state; retry with backoff; conflict-free (reports are append-only).
- **My Queue (Safety Officer):** triage, add evidence photos on scene, capture witness statements at the incident.
- **My Actions (owner):** update progress, attach completion evidence, from a magic link — no app install, no password.
- **Executive mobile:** Home renders fully responsive (scores + feed + KPI strip); board pack shareable from phone.
- **i18n at MVP:** capture surface ships BM + EN; full-app i18n framework in place from day one (all strings externalized), additional locales (ID, VN, ZH) as market demands.

18. Notification Strategy

Philosophy: notifications are the enforcement arm of the Decision Feed. Every notification must be actionable (deep link to the exact task), role-appropriate, and aggregated before it becomes noise. Noise = uninstall.

Channels: in-app center (MVP) · email (MVP) · web push (MVP, PWA) · WhatsApp Business (v2) · SMS (v2, critical-only fallback).

Event matrix (MVP):

Event	Audience	Channel & timing
Critical/Serious incident reported	Site Mgr, Safety Officer, HSE Mgr	Push + email, immediate; Executive brief within 24h (digest item)
Report awaiting triage > 24h	Site Safety Officer → Site Mgr at 48h	Email daily until cleared
Action due T−7 / T−2	Owner	Email + push
Action overdue T+0	Owner	Daily digest entry
Action overdue T+5	Owner + Site Manager	Email escalation
Action overdue T+10	+ HSE Manager + Decision Feed item	Email + feed
Verification requested / rejected	Verifier / Owner	Push + email

Event	Audience	Channel & timing
RCA awaiting approval > 3 days	Approver	Email
Audit finding due in 14 / 7 days	Finding owner, HSE Mgr	Email
Score band change (site crosses threshold)	HSE Mgr, Executive	Feed item + weekly digest
Weekly digest	Role-tailored per user	Email, user-chosen day (default Mon 08:00 site tz)

Rules: per-user preferences with sane role defaults; quiet hours (default 21:00–07:00 site tz) hold everything except Critical incidents; per-entity aggregation (one thread per action, not one email per event); every email footer explains why it was sent; delivery logged to `notifications.channels_sent` for the audit trail; escalation schedule is tenant-configurable with our ladder as default.

19. Security Strategy

Safety data is legally sensitive: injury records (personal data under PDPA), potential litigation evidence, regulator submissions.

MVP baseline:

- AuthN: email + password (argon2id, breach-list check, no forced rotation), optional TOTP 2FA (enforceable tenant-wide), rate-limited, session revocation; magic links (single-use, 7-day, scope-limited) for action owners.
- AuthZ: RBAC per §14, deny-by-default middleware; Postgres RLS as the second wall; separation-of-duties rules server-side.
- Data: TLS 1.2+; AES-256 at rest (DB + object storage); evidence via short-lived signed URLs; SHA-256 checksums on evidence (chain-of-custody for legal defensibility); no PII in URLs or logs.
- Audit: append-only `audit_log` on every mutation, DB-level (the app role has no UPDATE/DELETE on it); admin views for HSE Manager/Org Admin.
- AppSec: OWASP ASVS Level 2 as the engineering bar; dependency scanning + secrets scanning in CI; secrets in a managed vault, never in repo (we already learned this lesson with the wrangler token).
- Ops: daily encrypted backups, **restore tested monthly** (a backup is a rumor until restored); RPO 24h / RTO 4h at MVP → RPO 1h in v2; infra in SG region for SEA data-residency expectations.

Roadmap: v2 — SSO (SAML/OIDC), SCIM, IP allowlists, configurable retention, DPA templates, pen test before first enterprise contract. v2–v3 — SOC 2 Type I → Type II, ISO 27001 program, PDPA (MY) + PDP (ID) compliance documentation, single-tenant tier.

20. Future AI Strategy

Principle: AI is a feature of the Decision Feed, not a chatbot bolted on. The feed's UI contract (insight + evidence + recommended action) was designed so model-generated items slot in beside rule-based items with no UX change. Sequencing is dictated by data availability:

- **Phase A — Assistive (needs no history; fast-follow after MVP):** narrative → suggested classification (type/severity/RCA category) with confidence, human confirms; investigation-summary drafting; BM↔EN translation of narratives and witness statements. Cheap wins that reduce Safety Officer typing time massively.
- **Phase B — Analytical (needs ~6 months tenant data):** similar-incident retrieval via embeddings ("3 prior cases share this failed control"); weekly natural-language executive brief generated from the tenant's actual numbers; ask-your-data queries compiled to safe, tenant-scoped SQL.
- **Phase C — Predictive (needs 12+ months, multiple tenants):** leading-indicator risk models per site/department emitting feed items with confidence bands; anonymized cross-tenant benchmarking; regulation-watch mapping legal updates to affected clauses.

Guardrails (non-negotiable, and a sales asset in enterprise deals): AI suggests, humans confirm — no auto-classification or auto-closure ever; every AI-generated artifact is labeled and logged with model + prompt version in the audit trail; tenant data never trains shared models; per-tenant AI opt-out; evidence links on model-generated feed items point to the actual underlying data, same as rule-based items.

Build: LLM API (Claude) for A/B language tasks; classical ML on our own rollups for C. No GPU infrastructure; no fine-tuning until benchmarking proves need.

---

21. Appendices — Engineering Specifications

21.1 Incident State Machine (server-enforced)

```
REPORTED ──triage──▶ INVESTIGATING ──findings──▶ RCA_REVIEW ──approve*──▶ ACTIONS_OPEN
                                                                            │ all actions verified
   └▶ HAZARD (logged, action optional)                                      ▼
   └▶ DISMISSED (reason mandatory)                    CLOSED ◀──approve**── PENDING_CLOSURE
REOPENED: CLOSED → INVESTIGATING (HSE Manager only, reason mandatory)
```

* RCA approval by Site Manager+ required for Serious/Critical. ** Closure by Site Manager+; Critical requires HSE Manager. Guards: closure impossible with unverified linked actions; severity downgrades require reason + approval; all transitions audited. Invalid transitions = HTTP 422 regardless of client.

21.2 Taxonomies (tenant-extensible, defaults shipped)

- **Incident types:** slip/trip/fall · machinery · vehicle/pedestrian · falling object · work at height · chemical exposure · fire/explosion · electrical · loss of containment · lifting ops · occupational illness · property damage · environmental · security · other.
- **Severity:** Critical (fatality/major LTI/reportable) · Serious (LTI or high potential) · Moderate (medical treatment) · Minor (first aid/no injury). Definitions shown inline at selection — consistency of severity coding is what makes every rate metric meaningful.
- **RCA categories (fixed 5 for benchmarkability):** Unsafe Acts · Unsafe Conditions · Equipment Failure · Human Factors · Environmental Factors, each with shipped sub-categories (e.g., Human Factors → fatigue, competency gap, communication/handover, complacency, pressure/shortcuts).

21.3 Score Formulas (published; every weight visible in-product)

Safety Score (0–100, per site, monthly): `Score = 40·Lagging + 35·Leading + 25·Discipline`

- *Lagging:* TRIFR vs tenant target (piecewise: at-target=1.0, 2× target=0), severity-weighted (Critical×8, Serious×4, Moderate×2, Minor×1) incident rate vs trailing baseline.
- *Leading:* near-miss reporting rate vs target ratio (default 10:1), training compliance % (v2 input; until then weight redistributes), inspection completion % (v2; same).
- *Discipline:* action on-time closure % · overdue-age penalty (−2/action·week overdue, capped) · verification integrity (rejected verifications count against). Org score = hours-weighted mean of site scores. Components frozen in `score_snapshots.components` — historical scores never change retroactively; formula changes version the snapshot (`formula_v`).

Compliance Score: `Σ(clause_weight × status_value) / Σ(clause_weight) × 100` where compliant=1, minor=0.4, major=0, N/A excluded; majors carry 5× default clause weight. Per standard per site; org = mean weighted by standard criticality.

21.4 Decision Feed — MVP Rule Set

Rule key	Trigger	Recommended action
`site_score_decline`	Site score −5 pts in rolling 90d	Schedule site review; drill-down attached
`critical_cluster`	≥2 Critical/Serious at one site in 30d	Executive site review
`cause_acceleration`	RCA category ≥2× its 6-mo baseline for 2 consecutive months	Targeted intervention for category
`action_debt`	Overdue actions > threshold or oldest > 14d	Escalation summary with owners
`verification_stall`	Actions awaiting verification > 7d	Assign verifier

Rule key	Trigger	Recommended action
`audit_countdown`	Open majors with audit < 45d	Majors-first work list
`reporting_silence`	Site near-miss reports −50% vs baseline (under-reporting signal)	Reporting-culture check
`triage_backlog`	Reports untriaged > 48h	Clear queue

Each fires with evidence link + severity; dedupe window prevents re-firing while an item is active or snoozed.

21.5 Non-Functional Requirements

- **Performance:** Home TTI < 2s p75 on 4G; API reads p95 < 300ms, writes < 600ms; dashboards read snapshots/rollups only; tested at 50 sites / 10k incidents / 50k actions per tenant.
- **Availability:** 99.9% target; status page; graceful read-only degradation.
- **Accessibility:** WCAG 2.1 AA; charts follow the validated dataviz system (CVD-safe palette, no color-alone meaning, table alternatives).
- **Browsers:** evergreen Chrome/Edge/Safari/Firefox; Android Chrome + iOS Safari for capture.
- **Stack (proposed):** React + TypeScript + Vite (web), Node/TypeScript API (Fastify or NestJS), PostgreSQL + Prisma, Redis (queues/cache), BullMQ (jobs: escalations, digests, snapshots), object storage R2/S3 SG, IaC from day one. Monorepo. CI: typecheck, lint, unit, RLS cross-tenant suite, e2e smoke.
- **Observability:** structured logs w/ tenant+request IDs, error tracking, per-tenant usage metrics (activation dashboards are how we run the pilot program).

21.6 Open Questions (founder input needed)

1. **Brand:** company is "MedChain Enterprise" while the product is SafeOps — do we rename the company (recommend: yes, eventually "SafeOps Sdn Bhd"; medical branding confuses safety buyers)?
2. **Design partners:** which 3 companies do we pursue first? (Pilot pricing: free 90 days → founder-signed annual.)
3. **Anonymous reporting default:** on or off per tenant? (Recommend: on — unions and culture vary; make it a tenant switch, default on.)
4. **JKKP form formats:** need legal/consultant verification of current DOSH submission requirements before committing v2 scope.
5. **WhatsApp Business API:** approve the account setup + per-message cost model for v2?

End of PRD v1.0 — awaiting founder approval. On approval, development begins with Module M1 (Foundation), one module at a time, each with its own technical design review before code.